

Acta de construcción y publicación · Backend

Campo	Dato
Proyecto	CasaRoca System · Sistema 100p
Componente	Backend (base de datos y servicios)
Fecha de corte	11 de septiembre de 2026
Repositorio	<code>github.com/100p-NANO/ecosistema-cr</code> , carpeta <code>backend/</code>
Estado	Construido, probado y publicado

1. Objeto de este documento

Dejar constancia formal de qué se construyó en el backend del Sistema 100p, qué quedó publicado en el repositorio de la iglesia, y con qué evidencia se sostiene cada afirmación.

Todas las cifras de este documento se obtuvieron **ejecutando la base de datos**, no leyendo el código. La corrida de referencia es del 11 de septiembre de 2026 y es reproducible con los tres comandos de la sección 6.

2. Publicación en el repositorio

El código dejó de vivir en carpetas sueltas del equipo consultor y quedó bajo la cuenta de la iglesia. Esto es lo que permite la revisión línea por línea que solicitó la dirección técnica.

Concepto	Dato
Repositorio	<code>github.com/100p-NANO/ecosistema-cr</code>
Cuenta propietaria	<code>100p-NANO</code> (<code>100p@casaroca.org</code>)
Visibilidad	Privado, por invitación
Rama	<code>main</code>
Archivos publicados	396 en total, de los cuales el backend aporta 84
Commits del corte	<code>745b20f</code> (consolidación) y <code>f7125b7</code> (corrección de seguridad)

Se verificó que no se publicó ningún archivo de credenciales, ningún `.env` y ninguna dependencia compilada. La revisión de secretos previa a la publicación dio cero hallazgos.

3. Qué quedó construido

3.1 Modelo de datos

Elemento	Cantidad
Migraciones SQL, planas y en orden	32
Líneas de SQL	3.842
Esquemas de negocio	13
Tablas	59
Vistas	22
Funciones	50
Políticas de seguridad a nivel de fila	103
Disparadores de integridad	28
Juegos de datos de catálogo y demostración	7

Los trece esquemas cubren el modelo completo acordado en la mesa de trabajo: Núcleo, 01 Organización, 02 Identidad, 03 Grupos, 04 CRM, 05 Asistencia, 06 RocaKids, 07 Consejería, 08 Aportes, 09 Formación, 10 Talento, 11 Línea de tiempo y la Plataforma transversal, más la Consola de sistemas.

3.2 Servicios

Se construyó la API del **Módulo de Nuevos** en NestJS y TypeScript, escrita sobre el contrato publicado por el equipo de la iglesia, no sobre un contrato propio. Son 9 archivos de código fuente más su juego de pruebas de extremo a extremo.

3.3 Documentación entregada

Trece documentos en `backend/entregas-drive/`, organizados por la misma estructura de carpetas del Drive «Sistema 100p»: documentos base de arquitectura, observaciones al modelo de personas, empalme de módulos, modelo financiero recalculado sobre GCP y guía de operación de la base.

4. Qué quedó demostrado

Cada garantía del diseño tiene una prueba que falla si alguien la rompe. No son pruebas de que el código corre: son pruebas de que **la regla de negocio se cumple aunque el programador se equivoque**.

Banco de pruebas	Qué demuestra	Resultado
invariantes	Garantías del núcleo: menores, consentimiento, clasificación de datos	16 / 16
aislamiento_rols	Una sede no ve a otra, ejecutando con el rol de la aplicación	9 / 9
invariantes_modulos	Esquemas 03 a 10: grupos, asistencia, RocaKids, consejería, aportes, formación, talento	21 / 21
consola_sistemas	Módulos, habilitación por iglesia y matriz de permisos	25 / 25
empalme_100p	El contrato con los módulos de Roles, Nuevos y Donaciones	12 / 12
rols_tablas_hijas	La corrección del 11 de septiembre (ver sección 5)	6 / 6
Total		89 / 89

Resultado de la corrida de referencia: **32 migraciones aplicadas sin un solo error, 89 pruebas ejecutadas, 89 aprobadas, o fallidas.**

Las garantías más relevantes para la dirección:

- **Aislamiento entre sedes.** Las pruebas se ejecutan con el rol de la aplicación, no como superusuario. Probarlo como superusuario no demostraría nada, porque el superusuario siempre omite la política.
- **Protección de menores.** Un menor sin acudiente hace fallar la transacción. La entrega de un niño exige acudiente autorizado y código correcto, y el código va cifrado: se verifica, nunca se devuelve. Los intentos fallidos quedan registrados aunque la entrega se rechace.
- **Habeas Data (Ley 1581 de 2012).** El consentimiento es un registro que solo se agrega, con finalidad, canal, evidencia y fecha. Sin registro, la función de contacto devuelve falso.
- **Aportes.** La reconciliación es aritmética: una vista indica si lo migrado cuadra al peso con el cierre de control. El pastor congregacional ve hábito de aporte sin ninguna columna de monto.
- **Auditoría.** Registro que solo se agrega, inmutable y particionado, con bitácora de lectura sobre los datos de mayor sensibilidad.

5. Correcciones de seguridad del 11 de septiembre

La auditoría de este corte se hizo contra la base en ejecución y encontró dos defectos que el banco de pruebas anterior no detectaba. Ambos quedaron corregidos en la migración **0031**, cada uno con su prueba.

5.1 Tablas hijas sin política de seguridad

La protección por sede se había aplicado a las tablas principales (personas, grupos, casos, servicios, cohortes, aportes) pero no a las tablas que registran **quién se inscribió, quién asistió y quién es acudiente de quién**. Dieciséis tablas quedaban legibles sin filtro.

Evidencia: una sede sin ninguna persona registrada podía leer los certificados de aporte y las inscripciones de formación de otra sede. Entre las tablas expuestas estaban las de RocaKids, que contienen datos de menores.

Corrección: cada tabla hija hereda ahora la visibilidad de su tabla padre. La política no repite el filtro de sede, sino que pregunta si el padre es visible. Así existe una sola fuente de verdad: si la regla de sede cambia, cambia en un solo lugar.

5.2 La aplicación podía elevar su propio techo de acceso

El rol con el que se ejecuta la aplicación tenía permiso de escritura sobre la matriz de permisos, que es la tabla que define hasta qué nivel de sensibilidad puede llegar cada rol.

Evidencia: operando con el nivel de acceso más bajo, la aplicación reescribió las 173 filas de la matriz asignándose el nivel máximo.

Corrección: se retiró a la aplicación el permiso de escritura sobre los ocho catálogos que definen los permisos. Esos catálogos los escribe la consola de sistemas o una migración con acta de respaldo, nunca el rol de ejecución.

5.3 Control para que no vuelva a ocurrir

Se añadió la vista `plataforma.v_control_rols`, que deja a la vista cualquier tabla que quede legible por la aplicación sin una sola política. Debe revisarse en cada corte.

Es la tercera vez que aparece el mismo patrón en este proyecto, después de la corrección de las vistas en agosto. La lección es explícita y conviene dejarla escrita: **el control se estaba poniendo donde se estaba mirando, no donde estaban todos los datos**. Una tabla vacía en los datos de demostración no prueba nada; la comprobación válida es comparar lo que ve una sede contra lo que ve otra, no contra cero.

6. Cómo reproducir estas cifras

Sin nube, sin contenedores y sin dependencias de red. Requiere PostgreSQL 16.

```
cd backend
./scripts/arrancar.sh      # levanta PostgreSQL 16 local en el puerto 5433
./scripts/migrar.sh        # recrea la base y aplica las 32 migraciones y los datos
./scripts/probar.sh        # ejecuta las 89 pruebas
```

La salida de la última instrucción imprime el veredicto de cada invariante y el total por banco.

7. Asuntos abiertos que requieren decisión de la mesa

1. **La tabla de personas del modelo del equipo no tiene columna de sede.** Sin ella no es posible el aislamiento multisede para las 36 congregaciones. El detalle, con la corrección ya implementada, está en `backend/entregas-drive/01-Estructura-Datos/`.
2. **Región de nube.** Alojar en São Paulo en lugar de la región de Estados Unidos representa aproximadamente 575.000 pesos mensuales adicionales. La decisión depende de la cláusula de residencia de datos. El análisis está en `backend/entregas-drive/04-Infraestructura-Operacion/`.
3. **Llave de cifrado.** En desarrollo proviene de una variable de sesión. En producción debe provenir del gestor de llaves, nunca del código ni de una tabla de la propia base.

8. Advertencia de alcance

Este documento certifica que **lo diseñado y lo construido** cubre los controles descritos y que las pruebas los demuestran sobre el entorno de desarrollo. No certifica el comportamiento en producción: eso corresponde a la prueba de intrusión externa prevista en la compuerta G5 del plan de implementación.